

##CRISCb- IT Risk Assessment Practices

###Objectives:

At the end of this episode, I will be able to understand:

1. Risk is made up of a combination of factors
2. Risk factors are typically classified in two ways:
 - Contextual factors (internal/external)
 - Capability factors (ability to perform IT related activities)
3. Threat and Vulnerability landscape is in a constant flux
4. Use a Risk register to manage risk generated during the identification process
5. Risk analysis is the modeling of various threats against assets
6. Risk evaluation considers these risk events in context of the risk appetite, tolerance and capacity
7. Methods of Risk Identification include:
 - Historical or evidence based methods – Audit or incident reports, public media, annual reports
 - Systematic approaches or expert opinion- Risk team examines and questions a business process systematically. Vulnerability assessments, reviewing BCPs
 - Inductive methods or theoretical analysis. A team examines the process to determine the potential attack vector or compromise. Think Pen testing.
 - Risk library. Risk libraries are commonly used in GRC systems. These are pre-identified risks based on industry, market, etc.
8. The Risk Identification Process (in order):
 - Identify Assets
 - Identify Threats
 - Identify Existing Controls
 - Identify Vulnerabilities
 - Identify Impacts
 - Risk Estimation Process

Additional resources used during the episode can be obtained using the download link on the overview episode.

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

<http://www.isaca.org>